Architectural Decision Record (ADR) – TRB Decision: Genie One

Document control	
Document ID	DR-2026-005
Document type	Decision Record
Date	2026-07-28
Status	Accepted
Review IDs	TRB-2026-005
Feature keys	Genie One@SQL & BI Analytics
Classification	Internal – Synthetic Sample

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

Decision Record ID: DR-2026-005
Title: Approve Genie One (SQL Query Generator) for PHI-Containing Data
Related Review: TRB-2026-005 (Genie One – SQL & BI Analytics)
Status: Accepted
Date: July 28, 2026

---

1. Context & Problem Statement

The Analytics team at Acme Health Plan requested approval to use Databricks Genie One for member data exploration and ad-hoc analytics queries. Genie One is a natural-language query generator (GA feature in Databricks). The team wants to use it for member claims analysis, enabling non-technical stakeholders to ask questions in English rather than writing SQL.

The Decision:
- Feature is GA and functionally sound
- Risk is centered on PHI disclosure in prompts and low-count aggregates in responses
- TRB needed to determine: Can this feature be safely used with member PHI?

---

2. Decision

APPROVED FOR USE WITH MEMBER PHI, CONTINGENT ON CONDITIONS

Genie One is approved for use by authorized analytics users when executing queries against member data (demographics, claims, coverage). Feature is PHI-eligible once conditions are met and verified.

---

3. Alternative Decisions Considered

Option A: Unconditional Approval
- Rationale: Feature is GA; Databricks has mature security controls.
- Risk: No audit control on natural-language prompts. Users could disclose PHI in queries (e.g., "Show me John Doe's claims"). LLM responses could reveal low-count cohorts (privacy attack).
- Decision: Rejected. Insufficient audit and monitoring.

Option B: Reject (Non-PHI Only)
- Rationale: Genie prompts could leak PHI; low-count suppression not built-in; too risky for HIPAA data.
- Risk: Blocks valuable analytic capability. Undermines governance (appears over-cautious).
- Decision: Rejected. Conditions can mitigate to acceptable level.

Option C: Conditional Approval ← SELECTED
- Rationale: Strong audit logging (captures prompts), response sampling (catches low-count issues), user training, and UC row filtering mitigate risks to acceptable level.
- Risk: Residual risk LOW if conditions executed well.
- Decision: Accepted. Conditions below provide necessary controls.

---

4. Conditions for Approval

All conditions must be satisfied and verified by TRB before Genie One is enabled for PHI queries.

Condition ID	Requirement	Verification Method	Owner	Dead-line	Status
COND-005-1	**Genie Query Audit Logging:** All Genie queries logged to	TRB audits system tables; spot-checks 5 logs for	Analytics Manager + Platform Engineering	Sept 15, 2026	[ ] Open

Condition ID	Requirement	Verification Method	Owner	Dead-line	Status
	Databricks system tables, including (1) user identity, (2) natural-language prompt, (3) generated SQL, (4) result count, (5) timestamp. Logs retained 180 days. Access to prompts restricted to CISO + Compliance Officer only.	completeness. Verify access controls on audit schema.			
COND-005-2	**Row-Level Access Control:** UC row filters enforced for all Genie queries. Test queries executed by TRB with 3 test identities (different roles) to confirm masking is applied. Verify users cannot see filtered rows.	TRB conducts test queries; documents results.	Analytics Manager	Sept 15, 2026	[ ] Open
COND-005-3	**Response Monitoring:** Monthly audit of 10 random Genie queries' results. Check for low-count aggregates (e.g., "Members with X: 1" or "Y = 2") that could reveal identity.	TRB reviews results; escalates if low-count data found. Requestor provides evidence of suppression.	Databricks Support + Analytics	Sept 15, 2026 & ongoing monthly	[ ] Open

Condition ID	Requirement	Verification Method	Owner	Dead-line	Status
	Suppress results with count < 5. Document any anomalies found.				
COND-005-4	**User Training:** All analytics users (5–10 people) complete "Databricks & HIPAA Data Handling" training module before being granted Genie access. Refresher training annually. Training covers: (1) don't include PHI in natural-language prompts, (2) prompt examples ("What are claims trends by region?" vs. "Show me John's claims"), (3) data governance, (4) incident reporting.	Training completion certificates uploaded to [Training Portal]. TRB verifies list before go-live.	Analytics Manager	Sept 15, 2026	[ ] Open

5. Consequences & Trade-offs

Benefits

- **Analytics Velocity:** Non-technical users (benefits managers, clinicians) can explore member data without writing SQL. Estimated 50% reduction in query time.
- **Self-Service Analytics:** Reduces dependency on data engineers for routine queries.
- **Adoption:** Enables clinician-facing decision support for member care management.

Risks & Mitigations

Risk	Sever-ity	Mitigation	Residual Risk
User discloses PHI in prompt (e.g., "Show me John Doe's claims")	High	**COND-005-1 & 4:** Audit logging + training. TRB escalates if found.	Low—training + monitoring
Genie response reveals low-count cohort (e.g., "Members with rare disease: 1")	Medium	**COND-005-3:** Monthly response sampling; suppress count < 5	Low—if sampled monthly
Unauthorized user queries member data	Medium	UC row filters (COND-005-2) + baseline access controls	Low—standard controls
Accidental export of Genie results	Low	Training (COND-005-4); depends on user discipline	Low—training

Operational Requirements

- **Monitoring:** Monthly result sampling + quarterly audit log review (TRB workload ~4 hours/month)
- **Support Model:** Databricks support for Genie bugs; Analytics team for user support
- **SLA:** 99.5% uptime; <4hr incident response (standard Databricks GA SLA)

---

6. Sunset & Re-review Conditions

Re-review Triggers:
1. **Annual:** If monitoring shows low-count suppression failures (>2 instances), or unauthorized prompt disclosures (>1), re-review required.
2. **Immediate:** If Databricks modifies Genie architecture (e.g., adds cloud-based LLM processing), CISO must reassess before continued use.
3. **Policy Change:** If Acme Health Plan adopts new data governance policy (e.g., PHI minimization), TRB will evaluate Genie compliance.

Sunset Clause: If conditions cannot be maintained (e.g., Databricks removes audit logging capability), TRB may issue sunset notice with ≤180 day wind-down.

---

7. Compliance & Regulatory Context

Regulatory Framework:
- **HIPAA Security Rule § 164.312(a)(2)(i):** Access controls (unique user identification, emergency access procedures, audit logging, encryption/decryption)
- **HIPAA Security Rule § 164.312(b):** Audit controls—audit records and reports on access and other activity

Acme Health Plan Policies:
- **POLICY-2024-DG (Data Governance):** Defines PHI handling, retention, and access review requirements
- **POLICY-2024-TRAINING:** Annual HIPAA training mandatory for all users with PHI access
- **POLICY-2024-INCIDENT:** Breach response includes investigation of system logs and audit records

Audit Trail & Retention:
- Genie query audit logs retained 180 days (per POLICY-2024-RETENTION)
- Prompts (sensitive) retained 180 days, access restricted to CISO/CPO
- Decision record and all TRB meeting minutes retained 7 years (per HIPAA requirement)

---

8. Implementation Timeline

Date	Event	Owner
July 28, 2026	TRB approves (COND approval vote)	TRB Board
July 29, 2026	Conditional Approval Letter issued	CISO
Aug 15, 2026	Conditions execution begins	Analytics Manager
Sept 15, 2026	Conditions verification complete	TRB Lead
Sept 16, 2026	Genie One go-live approval issued	CISO
Sept 16, 2026+	Feature available to analytics users	Analytics Manager
Monthly (ongoing)	Response sampling audit	TRB Compliance Officer
Quarterly (ongoing)	Audit log review + anomaly detection report	TRB Compliance Officer

---

9. Questions & Open Items

Q: What if Genie adds prompt-injection filtering (to prevent PHI disclosure)?
A: TRB would re-evaluate COND-005-4 (training may become less critical if Genie prevents dangerous prompts). Reassess during annual re-review.

Q: Can we expand Genie to other teams (e.g., Finance) without new TRB review?
A: No. Each new team requires TRB approval and condition verification. Same conditions apply, but training must be completed for all new users.

---

10. Decision Approval

TRB Board Vote (July 28, 2026):
- CISO: ✓ Approve
- Chief Privacy Officer: ✓ Approve
- Enterprise Architect: ✓ Approve
- Platform Engineering Lead: ✓ Approve
- Data Governance Lead: ✓ Approve
- Compliance Officer: ✓ Approve
- **Result: UNANIMOUS APPROVAL**

Decision Approved By:

[CISO Name], Chief Information Security Officer
Signature: _____ Date: July 28, 2026

[CPO Name], Chief Privacy Officer
Signature: _____ Date: July 28, 2026

Implementation Contact:
[Analytics Manager Name] — [email@acmehealthplan.com]
Platform Engineering Lead: [email@acmehealthplan.com]

Audit & Retention:
This decision record is retained for 7 years and available to OCR / HHS HIPAA audits, annual IT audit, and incident investigations.

Classification: Internal – Synthetic Sample